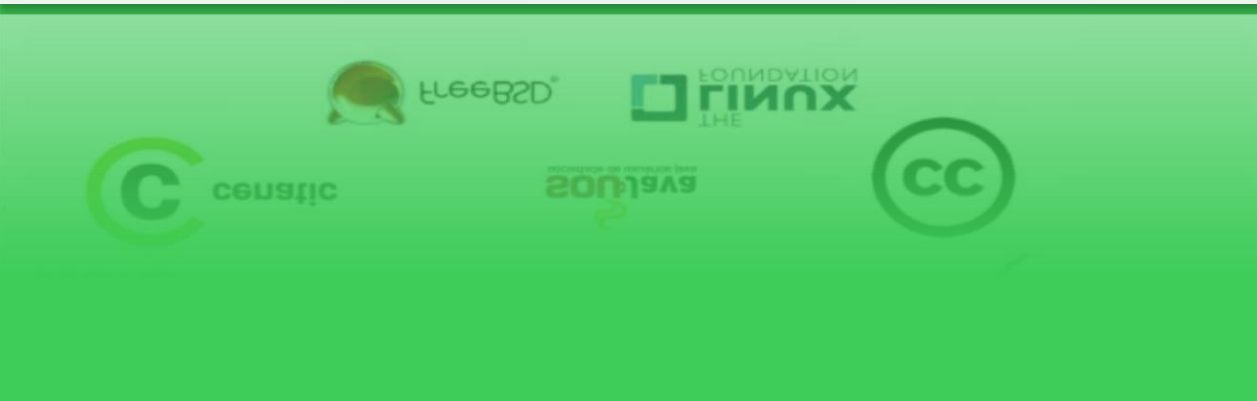




开源许可分享

DS安全&法务部
2022-05

Agenda



1

案例

2

历史

3

概念

4

开源许可

5

开源市场

6

许可选择

7

开源应用

8

参考资料

Life Is On

Schneider
Electric

开源 = 随意使用?



案例

开源软件

谨慎

2018

原告：数字天堂
(HBuilder)

被告：柚子公司
(APICloud)

判决：柚子公司停止侵权并赔偿71万元

2019

原告：不乱买
(海淘软件)

被告：闪亮时尚
(闪亮时刻)

判决：闪亮时尚停止侵权并赔偿25万元

2021

原告：罗盒公司
(Virtual APP 罗盒")

被告：玩友公司
(沙盒分身功能)

判决：沙盒分身功能全部代码开源
损害赔偿50万

历史

1969



1984



1991



1999



2007



1984



1985



1998



2004



2008



Life Is On

Schneider
Electric

历史

1969
UNIX 的诞生
AT&T 公司以低廉甚至免费的许可将 UNIX 源码授权给学术机构做研究或教学之用

1984
GNU 的诞生
理查德·斯托曼发起了 GNU 项目，**自由软件**这一现代概念诞生

1991
Linux 内核的诞生
Linux 内核填补了 GNU 用户需要完整的且使用自由软件的类 UNIX 系统的空白

1999
Red Hat 的 IPO
自由和开源软件具有商业意义

2007
Android 推出
移动设备操作系统

1984
AT&T 将 UNIX 商业化
将 UNIX 从研究性质的项目转变为一个商业项目

1985
自由软件基金会建立
FSF 帮助创建了保护 **GNU** 和其他自由软件项目的法律和制度框架。

1998
开源峰会
OSI 成立
开源软件 代替自由软件

2004
Ubuntu 推出
为普通用户提供相当稳定且拥有友好的界面

2008
GitHub 将开源“民主化”
使得更多开发者能更方便地参与开源项目

概念

FOSS

(Free and Open Source Software)是指自由和开放源码软件。这并不意味着软件是免费的。它意味着软件的源代码是开放的，任何人都可以自由使用、研究和修改代码。

四个基本自由：

1. 自由地运行软件
2. 查看源代码，如有需要，应允许用户修改代码
3. 将软件的副本分发给他人
4. 修改再发布，修改后的代码必须开放源代码。

概念

在开源领域中，存在着两大阵营：FSF & OSI

FSF

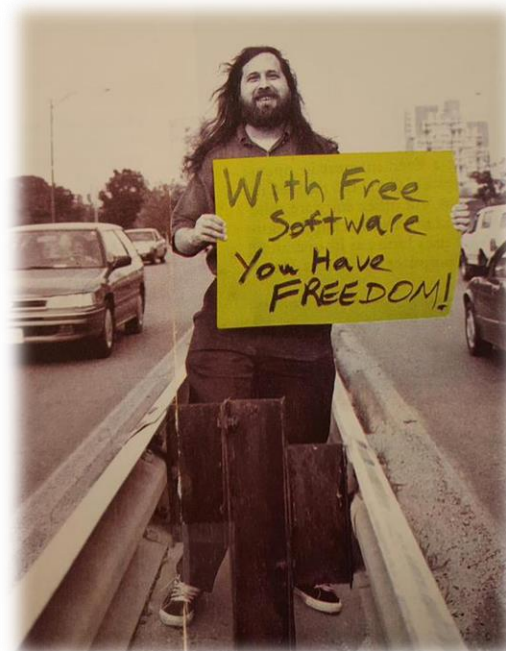
(Free Software Foundation,自由软件基金会) 自由软件基金会是在1985年10月由理查德·斯托曼建立，并提出“自由软件”的概念，为了该自由提出了**Copyleft** (自由) 概念，就是Copyright (版权) 的反义词。

FSF主要工作是运行 GNU 计划，开发更多的自由软件。

GNU

GNU计划的主要目的是创建一个自由的操作系统，其内容软件完全以GPL方式发布。名称来自GNU 's Not Unix!的递归缩写，因为GNU的设计类似Unix。

- GNU/Linux (GCC, Glibc) ;
- GNU 许可 (**GPL**, LGPL)



Life Is On

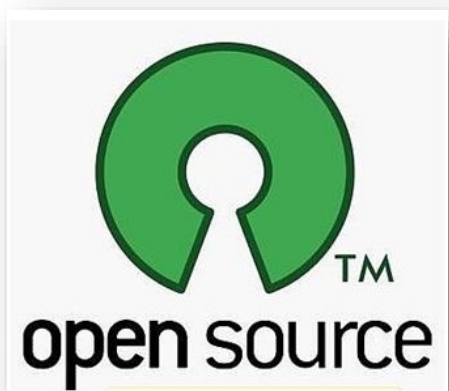
Schneider
Electric

概念

OSI

(Open Source Initiative, 开放源代码促进会)，在1998年OSI正式成立，因为FSF提出的“自由软件”很容易给人带来免费自由的误解，同时“自由软件”对于个人开发者来说很喜欢，但是对于企业来说想继承发展“自由软件”会有一些顾虑。

经过头脑风暴，Christine Peterson想到了“开源 (Open Source)”一词，得到大家的认可，并且“开源软件”这个词还得到Linus Torvalds (Linux之父) 和Richard Stallman (自由软件FSF之父) 的认可。



<https://opensource.org>

Popular Licenses

The following OSI-approved licenses are popular, widely used, or have strong communities:

- Apache License 2.0
- BSD 3-Clause "New" or "Revised" license
- BSD 2-Clause "Simplified" or "FreeBSD" license
- GNU General Public License (GPL)
- GNU Library or "Lesser" General Public License (LGPL)
- MIT license
- Mozilla Public License 2.0
- Common Development and Distribution License
- Eclipse Public License version 2.0

- Eclipse Public License version 2.0
- Common Development and Distribution License
- Mozilla Public License version 2.0

Life Is On

Schneider
Electric

概念

Copyright

著作权（版权），是作者对作品享有的一系列权利，也是所有权人能**阻止他人行使**的一系列权利，就软件来说，一般包括：复制权、发行权（信息网络传播权）、修改权、翻译权等，具体需要参照当地法律。

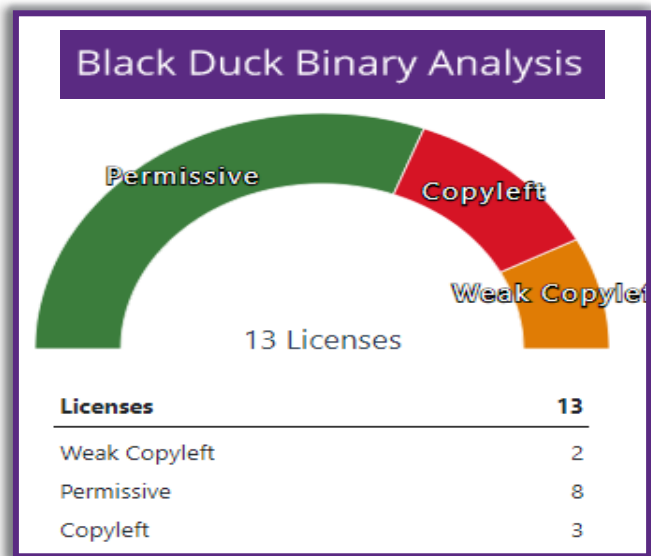
License

许可，在**保留版权所有权**的基础上，**作者给予他人的一系列使用权**，使用权的范围可由作者按照自己的心意进一步界定。例如：作者可以允许复制、发行，但不允许修改。

Copyleft

著佐权，作者保留著作权的所有权，通过在作品中**添加开源协议（license）**，给予用户的较大的权利，但用户要将衍生作品**开源**。

- 常见开源许可证分为两大类：**宽松自由软件许可证**（Permissive）和**著佐权许可证**（Copyleft）。
- 差别：在软件被修改并再发行时，Copyleft 强制要求公开源代码，而 Permissive 不要求公开源代码。
 - **Permissive** :Apache、MIT、BSD；
 - **Copyleft** :GPL、AGPL；
 - **Weak Copyleft**: LGPL、MPL。



开源许可- -如何学习一个许可

<https://opensource.org>

许可结构：

1. 术语定义
2. 享有权力*
3. 许可条件*
4. 许可模板

Apache License

Version 2.0, January 2004

<http://www.apache.org/licenses/>

1. Definitions.

....."Licensor" shall mean the copyright owner or entity authorized by the copyright owner that is granting the License.

2. Grant of Copyright License.

Subject to the terms and conditions of this License, each Contributor hereby grants to You a perpetual, worldwide, non-exclusive, no-charge, royalty-free, irrevocable copyright license to **reproduce, prepare Derivative Works of, publicly display, publicly perform, sublicense, and distribute the Work and such Derivative Works in Source or Object form**

4. Redistribution.

You may reproduce and distribute copies of the Work or Derivative Works thereof in any medium, with or without modifications, and in Source or Object form, provided **that you meet the following conditions**:.....

9. Accepting Warranty or Additional Liability.

Copyright [yyyy] [name of copyright owner]

Licensed under the Apache License, Version 2.0 (the "License");
you may not use this file except in compliance with the License.
You may obtain a copy of the License at

<http://www.apache.org/licenses/LICENSE-2.0>

Unless required by applicable law or agreed to in writing, software
distributed under the license is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.

Life Is On

Schneider
Electric

开源许可--如何学习一个许可

“Following conditions:”

你可以以源码形式转发基于本程序的作品或修改的内容，需要满足以下几点要求：

- a) 该作品必须带有醒目的**修改声明**及**相应的日期**。
- b) 该作品必须带有醒目的**声明**，指出其在**本协议的条件下**发布。
- c) 你必须**按照本协议**将该作品**整体**向想要获得许可的人**授权**，本协议就此适用于**整个作品**，即其每一部分，**不管如何建包**。
- d) 如果该作品有交互式用户界面，则其必须显示适当的法律声明。

例外：

在一个存储或分发媒介上，有一个**聚合体**，由**覆盖作品**和其他**可分离的单体作品**组成，**单体作品**既不是**覆盖作品**的自然扩展，也不以**构筑更大的程序为目的**，则**单体作品**不需要适用**覆盖作品**的许可（例如GPL3.0）

GNU:

区别**两个可分离的程序**和一个拥有**两个部分的程序**的衡量标准主要是**通信机制和通信语义**，例如pipes、sockets和command-line arguments为通常两个独立程序之间的通信机制，但是如果通信语义足够紧密，交换了复杂的内部数据结构，那么即使采用上述通信机制也可以被认定为两个部分合并为一个程序

合作解读

SOS

开源许可- - Apache 2.0

Apache

非盈利开源组织Apache采用的协议，版本2.0。

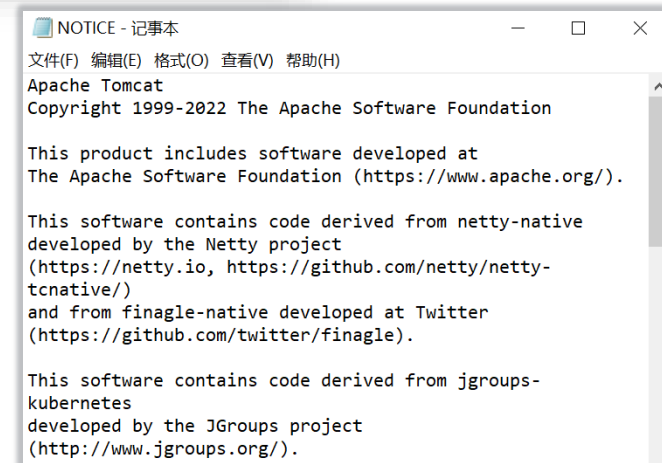
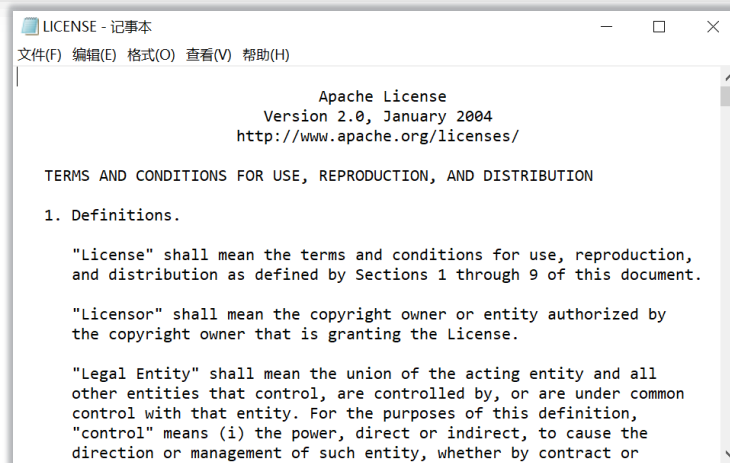
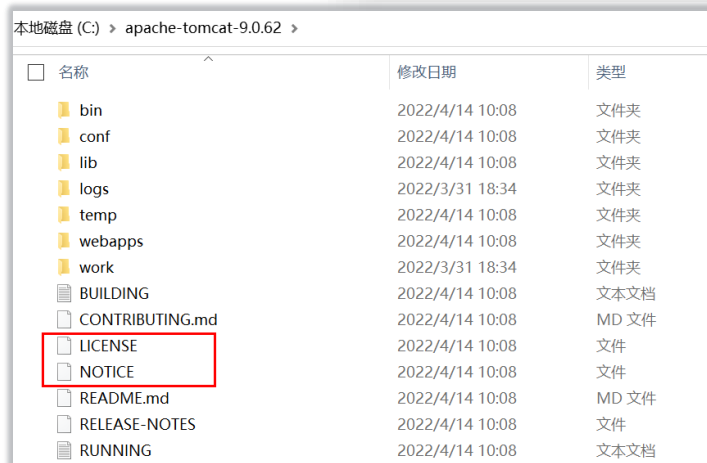
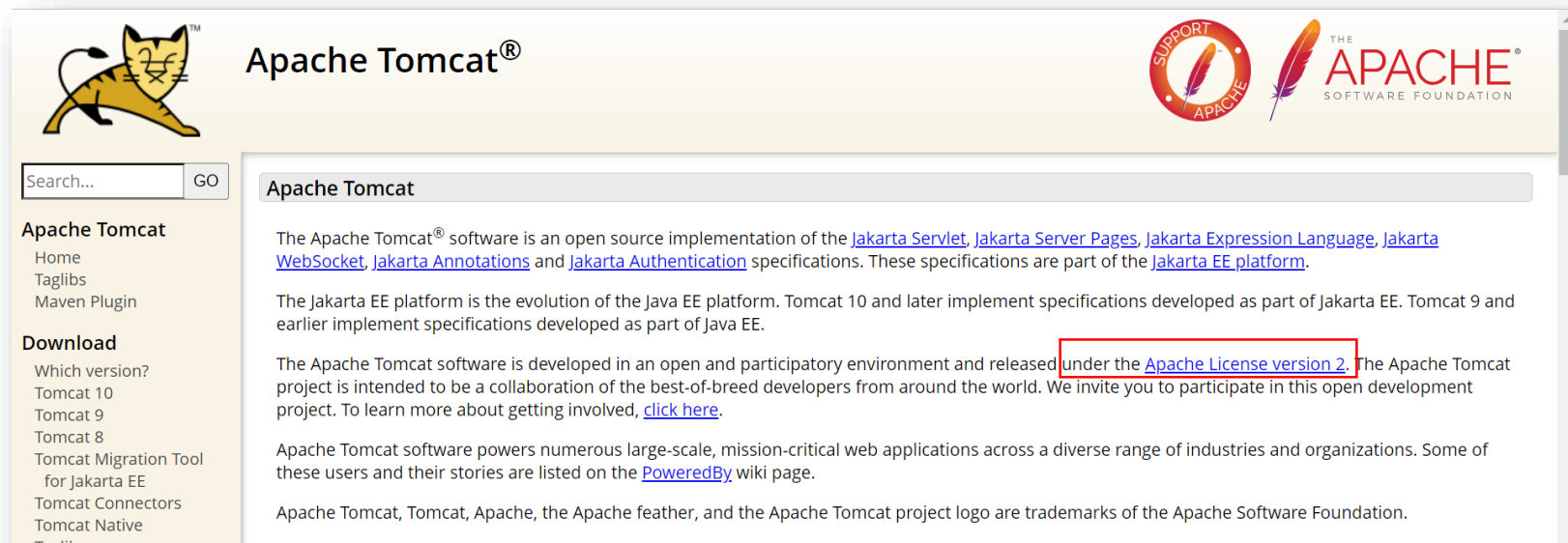
鼓励代码共享和尊重原作者的著作权，可以自由的下载和使用 Apache 软件，同样允许代码修改，再发布（作为开源或商业软件）。

限制：

1. 需要给代码的用户一份Apache Licence。
2. 如果你修改了代码，需要在被修改的文件中说明。
3. 在延伸的代码中需要带有原来代码中的协议，商标，专利声明和其他原来作者规定需要包含的说明。
4. 如果再发布的产品中包含一个Notice文件，则在Notice文件中需要带有Apache Licence。你可以在Notice中增加自己的许可，但不可以表现为对Apache Licence构成更改。



开源许可-- Apache 2.0



开源许可- - BSD

BSD (Berkeley Software Distribution)

BSD开源协议是一个给予使用者很大自由的协议。基本上使用者可以“**为所欲为**”，可以**自由的使用**，**修改源代码**，也可以将修改后的代码作为开源或者专有软件**再发布**。

限制：

1. 重新发布源代码必须**保留**上述版权声明、本条件清单和以下免责声明。
2. 以二进制形式重新发布必须在发布时提供的文档和/或其他材料中**复制**上述版权声明、本条件列表和以下免责声明。
3. 在没有事先书面许可的情况下，无论是版权所有者的**名字**还是贡献者的**名字**都**不能被用来支持或推广**本软件衍生的产品。

BSD有两种版本：

- New BSD License (“3-clause license”)
 - Simplified BSD License/FreeBSD LicenseLicense (“2-clause license”)。
- 区别是，后者忽略了非认可条款。



开源许可 -- MIT

MIT

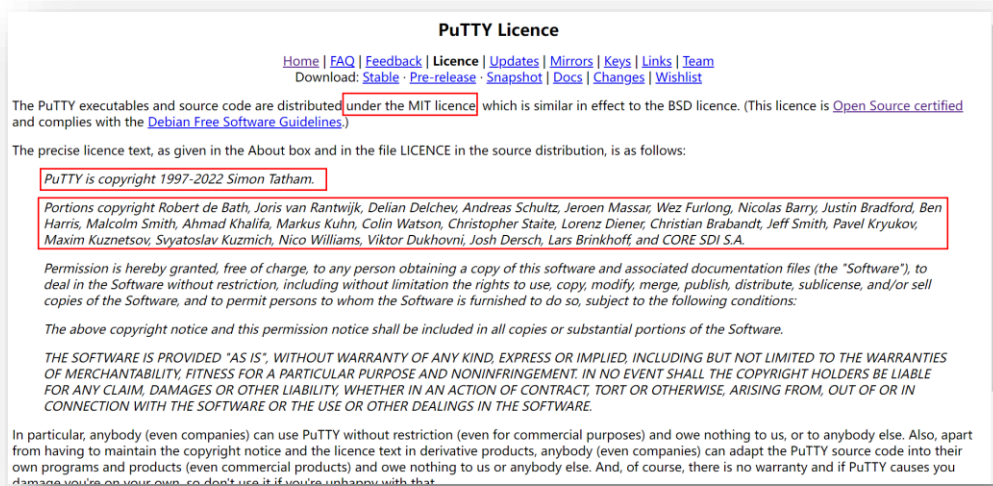
MIT之名源自麻省理工学院 (Massachusetts Institute of Technology, MIT) , 又称 “X条款” (X License) 或 “X11条款” (X11 License) ,是许多软件授权条款中, 被广泛使用的其中一种。

权利

- 被授权人有权利**使用、复制、修改、合并、出版发行、散布、再授权及贩售**软件及软件的副本。
- 被授权人可根据程序的需要**修改授权条款**为适当的内容。

限制

- 在软件和软件的所有副本中都**必须包含版权声明和许可声明**。



最广泛的许可

MIT许可证是应用**最广泛**的许可。SSH、PuTTY、X Windows System (X11)即为例子。

Life Is On

Schneider
Electric

开源许可 – 对比

License	Permissions	Conditions	Limitations
Apache License v2.0	✓ Commercial use ✓ Distribution ✓ Modification ✓ Patent use ✓ Private use	• License and copyright notice • State changes	× Liability × Trademark use × Warranty
The 2-Clause BSD License	✓ Commercial use ✓ Distribution ✓ Modification ✓ Private use	• License and copyright notice	× Liability × Warranty
The 3-Clause BSD License	✓ Commercial use ✓ Distribution ✓ Modification ✓ Private use	• License and copyright notice	× Liability × Warranty
MIT license (MIT)	✓ Commercial use ✓ Distribution ✓ Modification ✓ Private use	• License and copyright notice	× Liability × Warranty

开源许可- - GPL

GNU General Public License

GNU General Public License (GPL) 的可能是开源项目最常用的许可证。设计GPL协议目的很简单，就是给程序员自由，给用户自由！

权力

- 免费使用、复制、修改、分发受保护程序

限制

- **分发时一定要提供源码**
- **传染性：**一个作品用了GPL，他的儿子、孙子、世世代代都是GPL的。

GPL v1 1989

只发布二进制；软件许可中加入限制条件

GPL v2 1991

Liberty or Death

LGPL(GNU Lesser General Public License)

GPL v3 2007

解决软件专利、其他开源许可兼容性、源代码分区和组成的定义、解决数位版权管理问题

Schneider商业软件不允许使用GPL协议的代码！！！！

Life Is On



开源许可- - GPL & Android案例

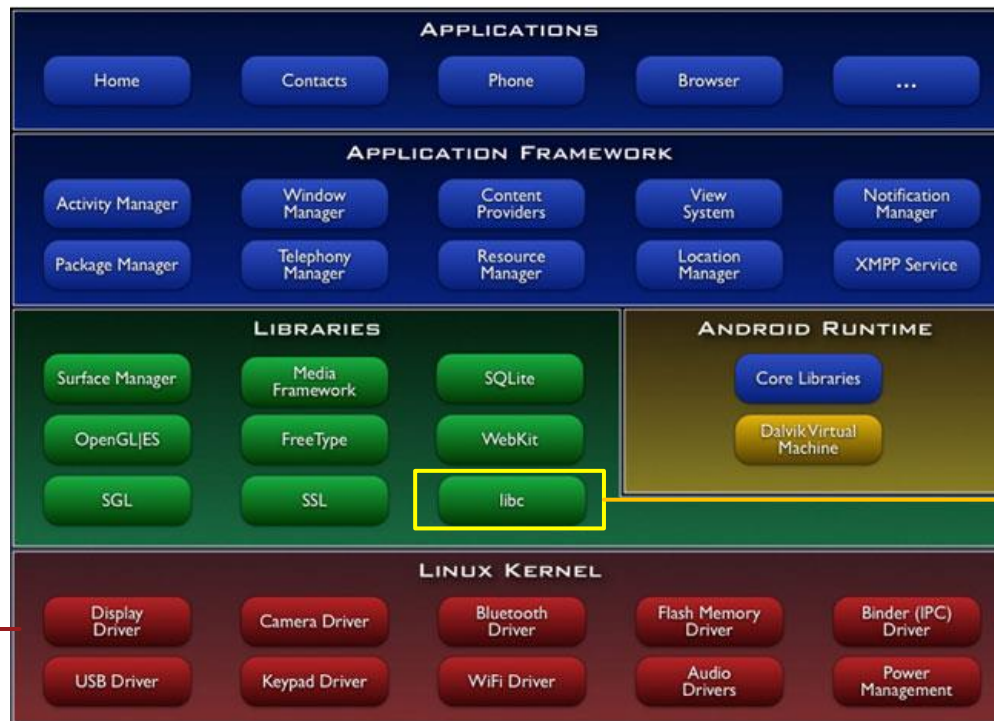
Android体系结构



开源许可- - GPL & Android案例

Android体系结构

Linux内核的版权是GPLv2，但是Linus Torvalds在Linux内核的版权文件增加了下面一段话，保证了Linux内核的商业用途不被GPLv2传染。



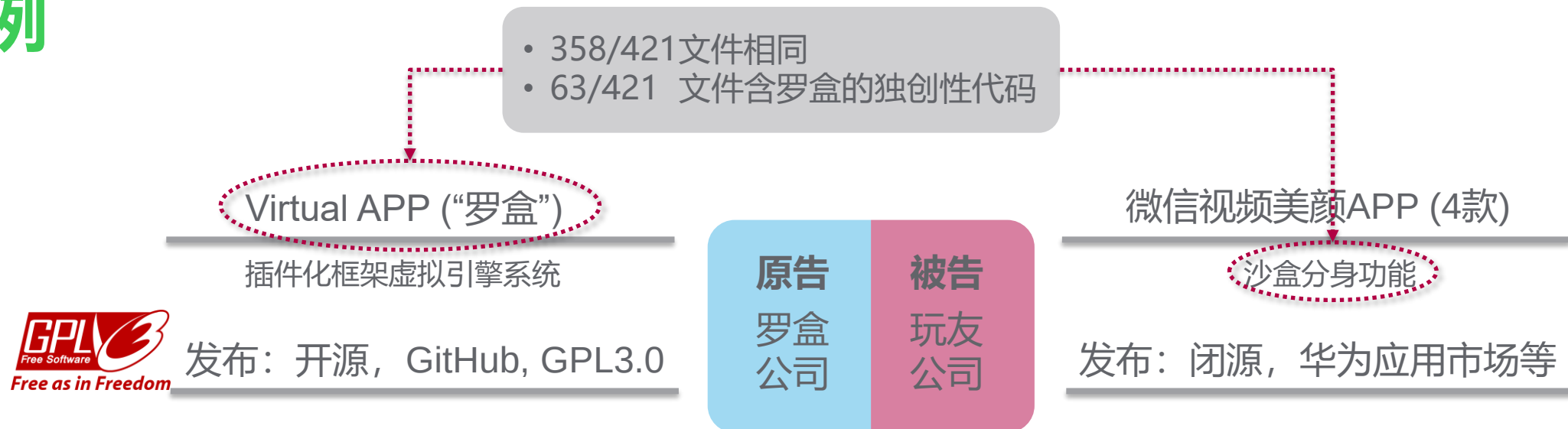
- GNU/Linux上图中的libc位置是Glibc。
- Glibc属于GPL授权，有传染性。
- **libc是google 改写的BSD Bionic库，属于BSD协议。**

NOTE! This copyright does **not** cover user programs that use kernel services by normal system calls - this is merely considered normal use of the kernel, and **does** **not** fall under the heading of "derived work".

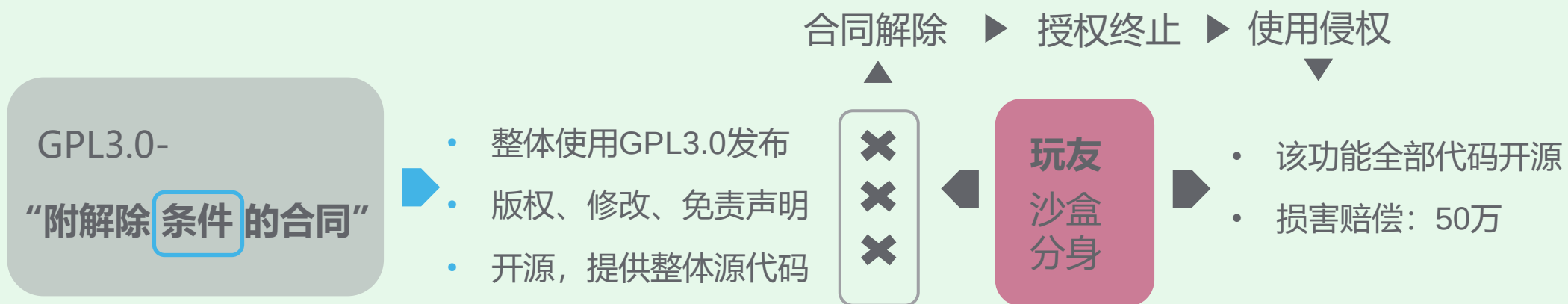
以上版权文件可以到Linux Kernel的网站下载：<https://www.kernel.org/>

案例

案情



法院判定



开源许可 -- AGPL

AGPL概念

AGPL的全称为：GNU Affero General Public License，是GPL的一个补充，在GPL的基础上加了一些限制。AGPL这个协议的制定是为了避免一个GPL/LGPL协议中的漏洞，称之为Web Service Loopwhole，这主要是由于GPL是针对传统的软件分发模式的商业模式。

协议特点

AGPL继承了GPL所有条款，并在此基础上增加了一条：

如果其许可下的软件**与用户通过网络进行交互**，那么就需要提供源代码给用户，所有的修改也同样要提供给用户。

开源许可 -- LGPL

LGPL概念

LGPL，即GNU宽通用公共许可证，是 GNU Lesser General Public License 的简称。它是由自由软件基金会(FSF)公布的自由软件许可证。

协议特点

LGPL和GPL不同，GPL要求任何使用/修改/衍生之GPL类库的软件必须采用GPL协议不同，**LGPL允许商业软件通过引用(dynamic link)的方式使用LGPL类库而不需要开源商业软件的代码。**这使得采用LGPL协议的开源代码可以被商业软件作为类库引用并发布和销售。

开源许可 --MPL

- MPL (Mozilla Public License) 是1998年初由Netscape公司设计。截至2021年1月5日，当前版本为MPL 2.0。
- MPL出现的原因，Netscape公司认为GPL没有很好地平衡开发者对源代码的需求和他们利用源代码获得的利益。

MPL同著名的GPL和BSD许可证相比，显著的不同之处主要在于：

1. 源代码共享

- MPL虽然要求对于经MPL许可证发布的源代码的修改也要再许可出来，但可以在源代码库上加一个接口，**可以将接口程序的源代码对外许可外**，为源代码用做自己商业软件开发的行为留了一个豁口。

2. 源代码混合

- MPL许可证第三条第7款中允许被许可人将经过MPL许可证获得的源代码同自己其他类型的代码混合得到自己的软件程序。**允许衍生项目中有私有模块的存在。**

3. 对软件专利的态度

4. 对源代码的定义

5. 关于对源代码修改进行描述

- 要求所有再发布者都得有一个专门的文件就对源代码程序修改的有描述



Life Is On

Schneider
Electric

开源许可 – 对比

License	Permissions		Conditions	Limitations
GNU General Public License (GPL) v2.0	✓ Commercial use ✓ Distribution	✓ Modification ✓ Private use	• Disclose source • License and copyright notice • Same license • State changes	× Liability × Warranty
GNU General Public License (GPL) v3.0	✓ Commercial use ✓ Distribution ✓ Patent use	✓ Modification ✓ Private use	• Disclose source • License and copyright notice • Same license • State changes	× Liability × Warranty
GNU Affero General Public License (AGPL) V3.0 (+ SaaS)	✓ Commercial use ✓ Distribution ✓ Patent use	✓ Modification ✓ Private use	• Disclose source • License and copyright notice • Same license • State changes	× Liability × Warranty
GNU Lesser General Public License (LGPL) v3	✓ Commercial use ✓ Distribution ✓ Patent use	✓ Modification ✓ Private use	• Disclose source • License and copyright notice • Same license (library) • State changes	× Liability × Warranty
Mozilla Public License 2.0 (MPL-2.0)	✓ Commercial use ✓ Distribution ✓ Patent use	✓ Modification ✓ Private use	• Disclose source • License and copyright notice • Same license (file)	× Liability × Trademark use × Warranty

开源许可 – 一分钟记忆



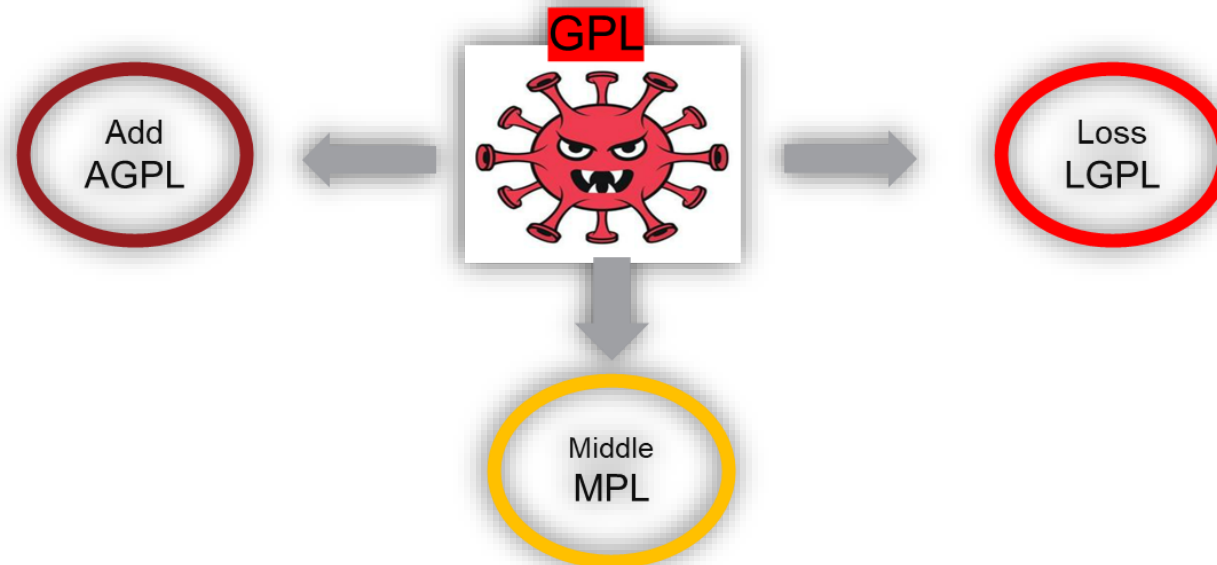
Apache



BSD



MIT

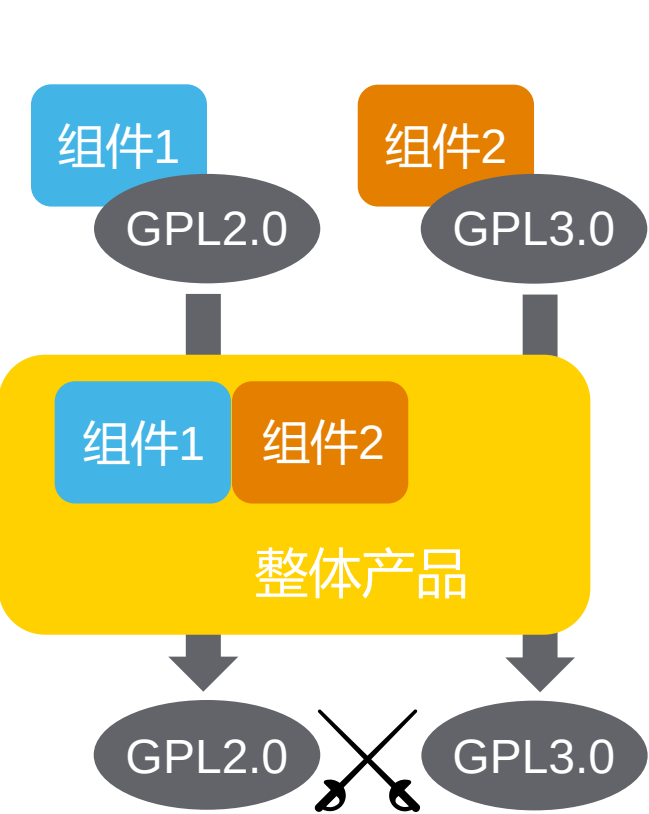


Internal

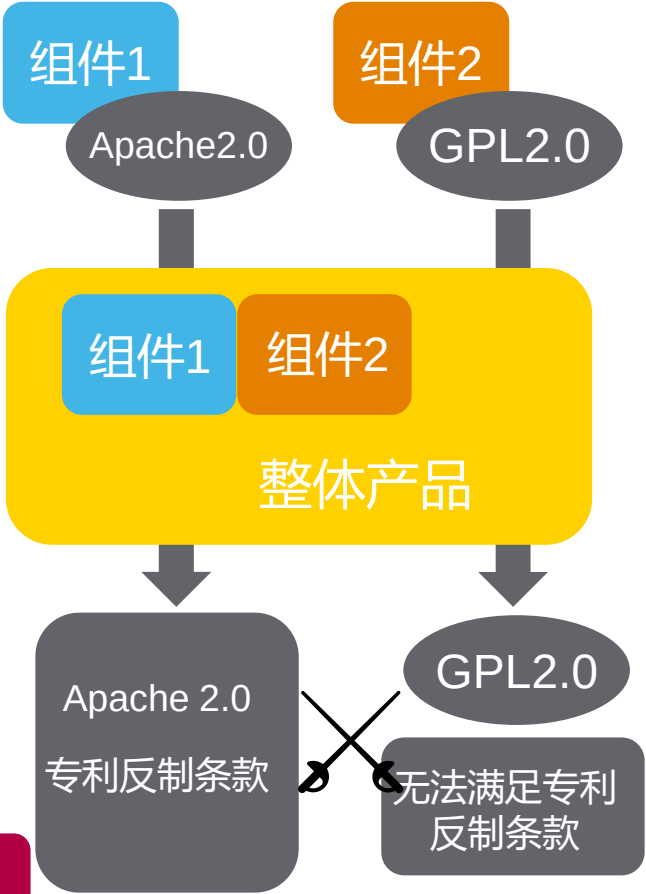
兼容性

一个软件中含两个以上开源组件共同发布

不兼容例1



不兼容例2



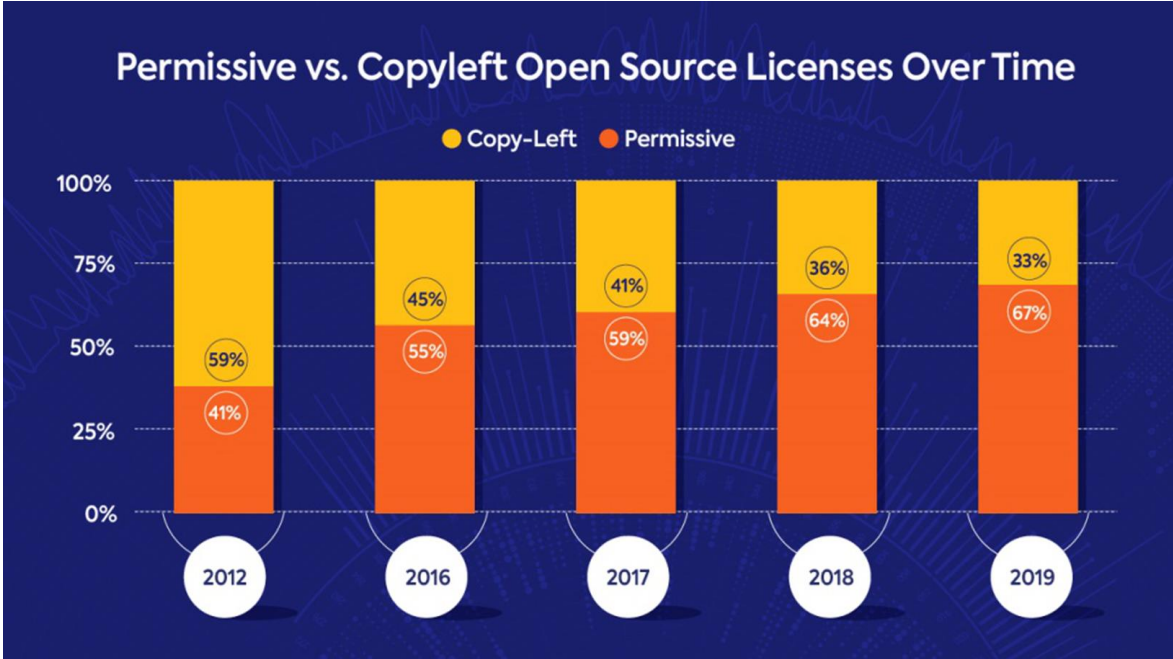
有冲突的协议无法在同一个软件中发布

	I WANT TO APPLY		
	GPL V2	GPL V3	LGPL 2.1
GPL V2	—	×	×
MIT	✓	✓	✓
Apache 2.0	×	✓	✓
GPL V3	×	—	×
BSD 2.0	✓	✓	✓
LGPL 2.1	✓	✓	—

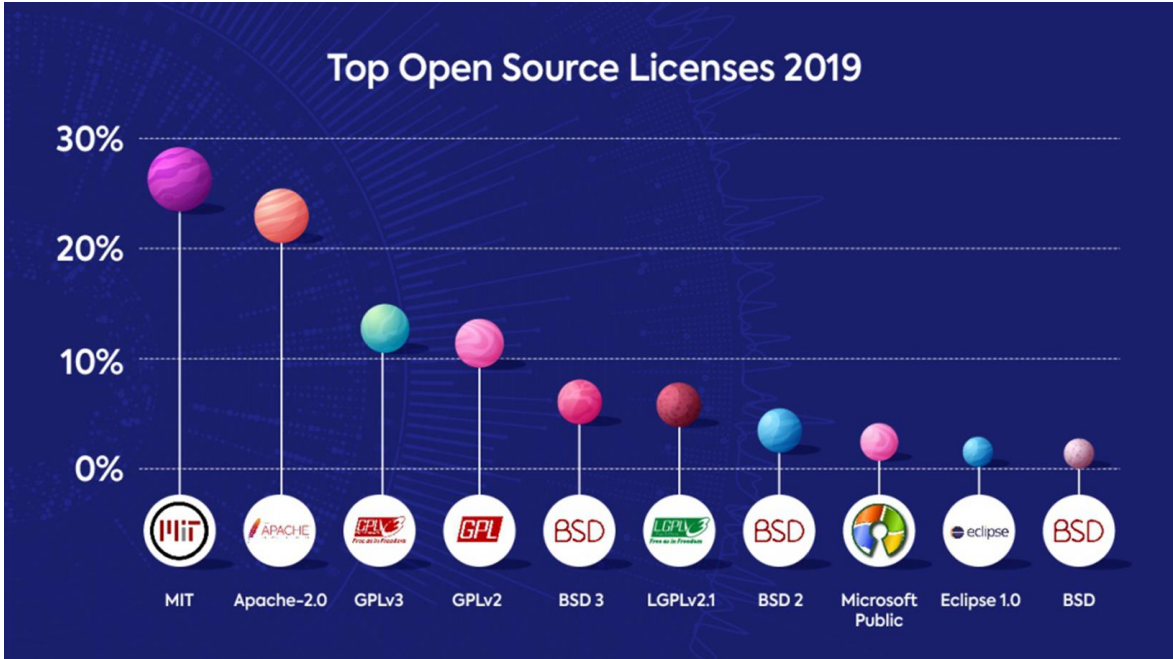
引用自Global Digital团队SoCoGo项目中的《Legal fundamentals in Software Engineering》

开源市场

宽松式开放源码许可证呈增长趋势

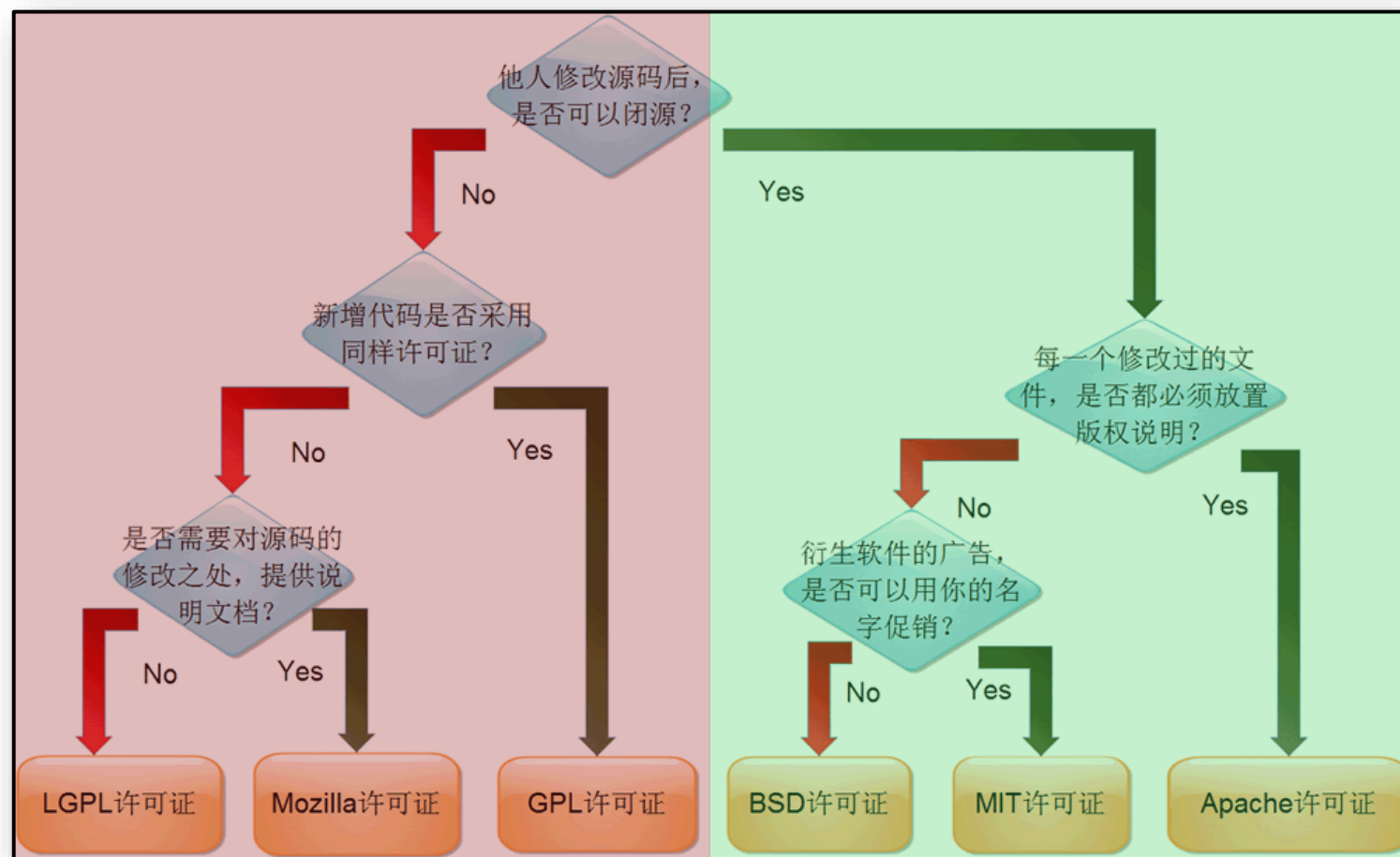


MIT开源许可证仍然位居榜首

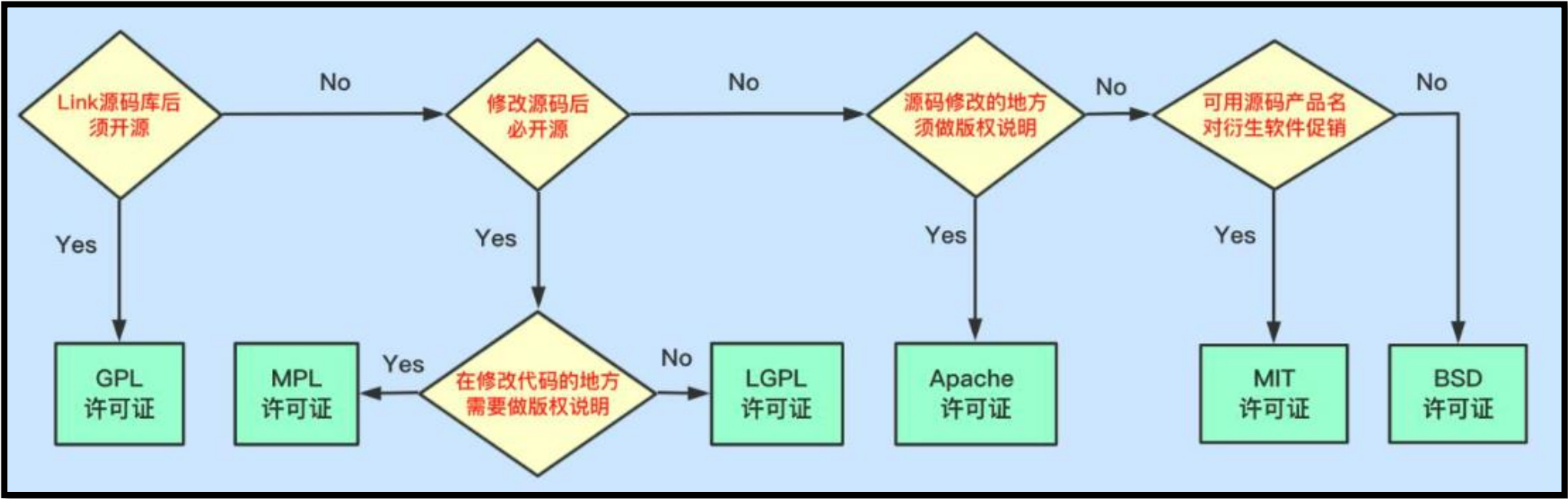


许可选择

乌克兰程序员 Paul Bagwell



许可选择



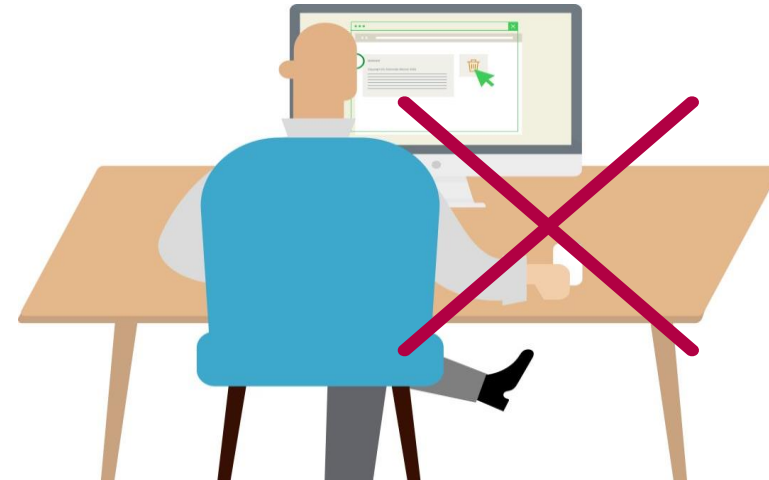
开源应用 -- Global

Mark all the changes and add notice

- Document all changes in the source code, clearly.

Do not remove existing notices

- Do not remove any existing notices, reference to license terms, warranty disclaimers, etc., found in the FOSS（通知、许可条款、担保免责声明）。



Life Is On

Schneider
Electric

开源应用 -- Global

Mixing GPL/LGPL code

- **Do not copy** any GPL/LGPL code into Schneider Electric proprietary code or code governed by other FOSS licenses.
- **Do not copy** Schneider Electric proprietary code or other FOSS into GPL/LGPL code, unless a conscious strategic decision has been made.

No GPL/LGPL in monolithic code

- Do not introduce GPL/LGPL code in Schneider Electric products if the generated image is **monolithic** (i.e. no kernel_space / User_space) .处发GPL和LGPL代码在静态链接时传播其许可的条款

No xGPL V3

- Do not introduce any GPL V3 or LGPL V3 into Schneider Electric products, whether kernel or user space, unless you have explicit permission.

开源软件使用风险提示

前期评估

考虑因素：

- 能否满足**开源协议的要求**、开源组件使用的协议之间**是否兼容**
- **使用方式**：开源软件代码是否要被修改或者整合到SE的代码当中，还是按原样使用
- **优于**其他商业软件或SE自有软件
- **高质量**开源软件，**代码成熟**
- **获得技术支持的难易度**——开源软件公司或社群的能力和活跃度
- 开源社区支持的**主流版本**还是其他衍生版本
- 开源软件的**声誉**——向客户披露时客户的认可度
- 后续**升级**或者**安全更新**谁来完成，包括谁来提供给客户
- **详实记录**

使用过程

- **不得超出**前期评估决定的使用**范围**
- **正规来源**：正规开源社区 v. 非正规镜像网站
- 按照开源协议**要求**作出：
 - ✓ 版权声明
 - ✓ 修改声明
 - ✓ 免责声明
 - ✓ 提供开源协议副本
 - ✓ 提供源代码
- **详实记录**

最终实际使用的开源软件、软件版本、使用方式、对应的开源协议、协议版本、如何去满足的协议要求

产品Review及后续管理

- 开源协议**符合情况**（包括主动披露开源软件的使用情况）、**兼容情况**
- 根据客户要求披露，**及时提供信息及解释**
- **定期升级**或者进行**安全更新**、**向客户提供**相应更新
- **定期监控开源协议**适用情况
- **详实记录**、保存记录

源代码扫描、审计和管理工具：**Black Duck**, Palamida, NexB, and Open Logic

《开源组件管理办法》

1.记录

- 所有的开源组件必须被记录和归档

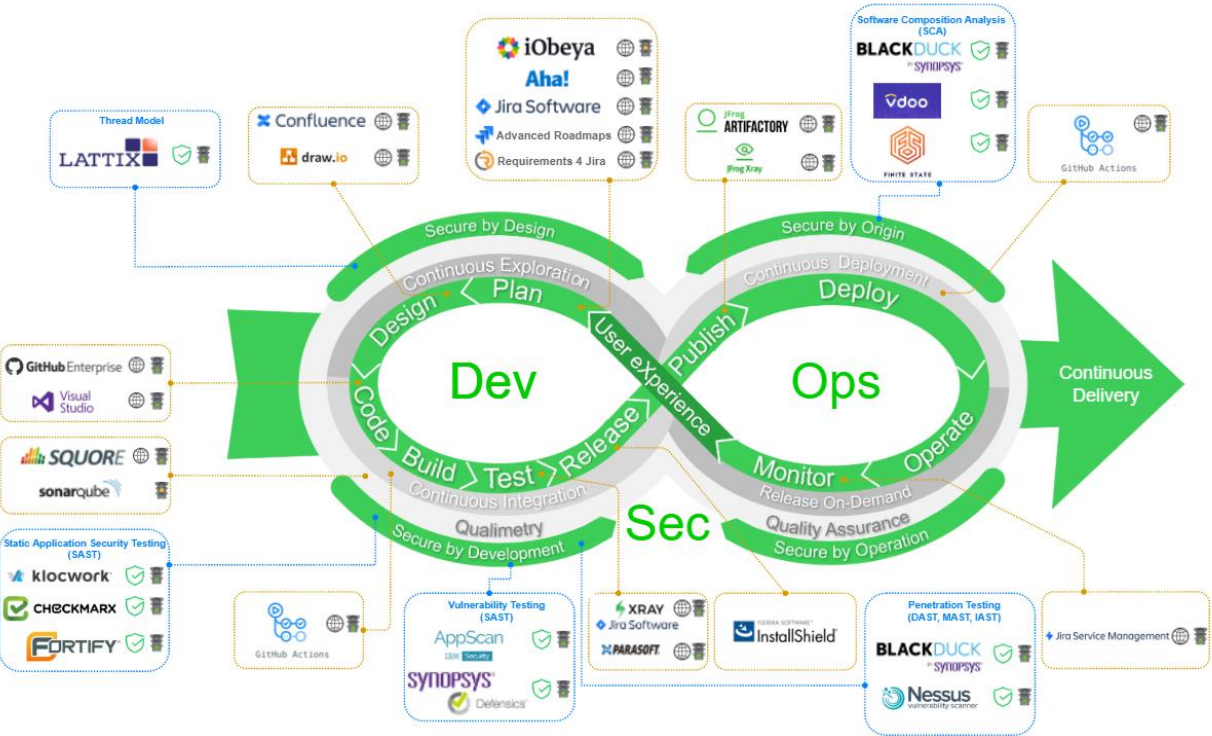
2. 优化

- 相似的开源组件，统一组件
- 相同的开源组件，统一版本
- 定期Review

3. 新增评估

- 评估方法
 - 开源组件评估：wiki《开源组件管理办法》
 - 开源组件的License如果存在法务问题(GPL,AGPL,LGPL)，需要进行替换
- 考虑因素
 - 幕后组织和社区活跃度
 - 通用度和成熟度
 - 技术人员熟悉
 - 技术趋势
 - 开源组件使用的协议之间是否兼容

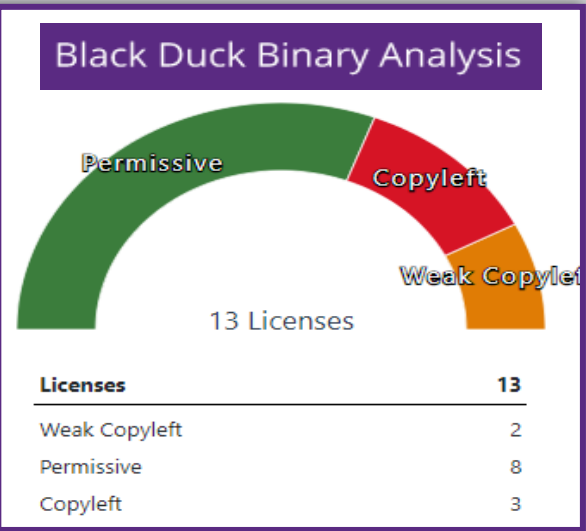
开源应用 – 工具



Publish



Deploy



Life Is On

Schneider Electric

参考资料

GPL案例

1. <https://zhuanlan.zhihu.com/p/97744548>
2. <http://www.foridom.com/index.php/Index/article/id/458>
3. <https://www.cnblogs.com/qcloud1001/p/12155117.html>

概念

1. <https://blog.csdn.net/cxu0262/article/details/107261659>
2. <http://c.biancheng.net/view/2947.html>
3. <https://www.zhihu.com/question/60887472/answer/2265268142>

官网

1. <https://www.gnu.org/>
2. <https://opensource.org/>

历史

1. https://www.sohu.com/a/195436425_760387
2. <https://zhuanlan.zhihu.com/p/150963217>

解读

1. <https://wenku.baidu.com/view/52b46c7a383567ec102de2bd960590c69fc3d874.html>
2. https://blog.csdn.net/weixin_39591031/article/details/118124495
3. <https://www.likecs.com/show-203587361.html>

4. <https://www.likecs.com/show-203951330.html>
5. <https://www.likecs.com/show-203930932.html>
6. <https://www.runoob.com/w3cnote/open-source-license.html>
7. <https://www.cnblogs.com/renfeng/p/10840518.html>
8. <https://baijiahao.baidu.com/s?id=1714201454077864474&wfr=spider&for=pc>
9. <https://baijiahao.baidu.com/s?id=1726797000415420806&wfr=spider&for=pc>
10. <https://blog.csdn.net/goodshanzi/article/details/120567319>
11. https://blog.csdn.net/Aria_Miaazy/article/details/103895088
12. https://www.sohu.com/a/385998754_468635
13. <https://blog.csdn.net/j3T9Z7H/article/details/106030124>
14. <https://baijiahao.baidu.com/s?id=1666100397386510286&wfr=spider&for=pc>
15. https://blog.csdn.net/lan_13217/article/details/83676988
16. https://blog.csdn.net/Change_Improve/article/details/105026641?utm_medium=distribute.pc_relevant.none-task-blog-2~default~baidujs_title~default-1.pc_relevant_antiscanv2&spm=1001.2101.3001.4242.2&utm_relevant_index=4
17. https://www.sohu.com/a/405427905_827544
18. <https://blog.csdn.net/kaiyuanshe/article/details/113787550>
19. https://blog.51cto.com/u_15270382/2909161
20. <https://zhuanlan.zhihu.com/p/350966700>

Life Is On

Schneider
Electric

开源许可 – 问答

1. 第一个开源系统是什么?

A. UNIX B. Linux C. Ubuntu D. Red hat

1.A

2. 第一个开源组织是什么?

A. FOSS B.FSF C. GNU D. OSI

2.B

3. 如果想了解所有开源许可, 访问哪个网站最合适?

A. gnu.com B. gnu.org C. opensource.com D. opensource.org

3.D

4. 市场应用最广泛的开源协议是什么?

A. Apache B.BSD C. MIT D. GPL

4.C

5. 具有传染性, 对程序的复制、修改和分发后需要公开源代码的许可?

A. Apache B.BSD C. MIT D. GPL

5.D

6. 在整个Dev&Ops过程中, Delpoy阶段可以使用开源合规扫描工具是?

A. Jfofg Xray B.BDBA C. SonarQube D. Nessus

6.B

Life Is On

Schneider
Electric

Life Is On

Schneider
Electric